may already have procedures in place to notify individuals affected by a data breach,[1065] the magnitude of this effect is difficult to estimate.

One commenter supported the proposed extension of the scope of the safeguard and disposal rules to all transfer agents and stated that it would promote fair competition among these firms by reducing asymmetry in the requirements with which different types of transfer agents must comply.[1066] We agree with this commenter that including all transfer agents in the scope of both the safeguards rule and the disposal rule will contribute to enhanced competition in the market for transfer agents.[1067]

With respect to efficiency and competition among covered institutions' service providers, the overall effects of the final amendments are difficult to predict. The final amendments require covered institutions to ensure that their service providers protect against unauthorized access to or use of customer information and notify the covered institution in case of a breach. The final amendments also require covered institutions to oversee their service providers to ensure that these measures are enforced.[1068] As discussed above,[1069] we expect that most service providers will continue their relationships with covered institutions, but some service providers might not. We expect that four possible scenarios may happen:

1065 *See supra* footnote 1002. In addition, we expect that many transfer agents already have some processes in place to contact customers since communicating information from the issuer to its security-holders is one of the core functions of transfer agents.

1066 *See* Better Markets Comment Letter.

1067 In particular, applying the final amendments to all transfer agents may be beneficial for competition, to the extent that applying different regulations to different entities could exacerbate existing differences in the competitive landscape. *See supra* section IV.C.3.e (discussing that transfer agents registered with the Banking Agencies are on average smaller than transfer agents registered with the Commission).

1068 *See* final rule 248.30(a)(5).

1069 *See supra* section IV.D.1.c.

- Scenario 1: The service provider already has the processes and procedures in place to satisfy the covered institution's obligations under the final amendments and is willing to cooperate with the oversight activities of the covered institution.
- Scenario 2: The service provider does not have the necessary processes and procedures in place but is willing to adapt them to satisfy the covered institution's obligations under the final amendments and to cooperate with the oversight activities of the covered institution.
- Scenario 3: The service provider does not have the necessary processes and procedures in place and is not willing to adapt to satisfy the covered institution's obligation under the final amendments.[1070]
- Scenario 4: The service provider already has the processes and procedures in place to satisfy the covered institution's obligations under the final amendments but is not willing to cooperate with the oversight activities of the covered institution.

Under scenarios 1 and 2, the relationship between the covered institution and its service provider is maintained. Hence, we do not expect significant effects on efficiency and competition in these cases.[1071] On the other hand, scenarios 3 and 4 imply that the covered institution will have to either switch to a new service provider or perform the former service provider's functions in-house. If the covered institution is unable to find a new service provider that is equivalent in its ability to provide the services, this is likely to result in a second-best outcome

---

[1070] *See supra* section IV.C.3.f. Because taking the appropriate measures to satisfy the amendments' requirements entails fixed costs, we expect that smaller service providers are more likely to exit (or not enter) this market than larger service providers.

[1071] The other benefits and costs of these scenarios are discussed in section IV.D.1.c.

for the covered institution and therefore to result in a loss of efficiency.[1072] Scenario 4 could also lead to covered institutions being forced to switch away from large, established service providers and instead to rely on smaller, less established providers that may be less capable of addressing the vulnerabilities within its control. This situation could result in a reduced ability to protect customer information.

Commenters identified service providers exiting the market as a significant potential cost of the proposed requirements.[1073] We expect that the changes that we have made to the final amendments, including the change from a written contract requirement to a requirement to oversee service providers and the change to an extended notification deadline of 72 hours, will reduce the likelihood of scenario 4 by giving covered institutions more flexibility in how they choose to satisfy the service provider requirements of the final amendments.[1074] This will reduce the likelihood of this potential negative outcome. However, such an outcome is still possible and to the extent that it occurs, it will represent a cost of the final amendments.

1072 Under scenario 3, we expect this effect on efficiency to be limited since the service providers who are the most efficient at the outsourced function are likely to also be more effective at protecting customer information. We expect this effect to be more significant under scenario 4.

1073 *See* ACLI Comment Letter ("If service providers are unable or unwilling to change their practices, this requirement could cause regulated entities to end essential service provider arrangements with inadequate alternatives"); SIFMA Comment Letter 2 ("Indeed, some service providers may not agree to the contemplated new terms, which could limit the number of service providers that agree to such requirements, causing an undue reliance on a small group of service providers in the industry. Another possible result is that the least commercially savvy service providers would agree to these terms, which could increase unqualified providers working in the industry."); CAI Comment Letter ("In practice, this will often force covered institutions to choose between either using the best and most dependable service providers or complying with these regulatory requirements, since many leading service providers (such as cloud service providers) do not negotiate the standard terms of their services with customers and those standard terms generally would not meet the proposed contractual requirements.").

1074 *See supra* section II.A.4. In addition, some commenters mentioned costs associated specifically with written contracts. *See, e.g.*, ASA Comment Letter; IAA Comment Letter 1. These contracting costs could also apply to service providers and potentially result in these service providers terminating their relationship with covered institutions.

Because scenarios 3 and 4 result in service providers exiting the market, they also have effects on competition. While scenario 3 would result in an overall decrease in the number of service providers available to covered institutions, it would not necessarily reduce competition among service providers who are able and willing to satisfy covered institutions' requirements. In fact, the final amendments will prevent service providers that are not willing to satisfy the minimum requirements from operating in that market and from potentially undercutting service providers who do satisfy the requirements. This will improve the competitiveness of the service providers who are able and willing to satisfy the requirements. The situation is different for scenario 4, which would result in a decrease in the number of service providers with adequate customer information safeguards and notification procedures. This would result in a decrease in competition, and this is a potential cost of the regulation.

One commenter stated that the proposed amendments could lead to service providers not agreeing with the new requirements, adding that it could result in covered institutions relying on a small group of service providers in the industry.[1075] This commenter also stated that some service providers may choose not to enter into agreements with covered institutions as a result of the proposed amendments.[1076] We acknowledge that this is a risk of the final amendments. However, we expect that the modifications that we have made to the service provider provisions of the final amendments will reduce the costs to service providers of satisfying covered institutions' requirements,[1077] and might therefore reduce the likelihood of this potential negative outcome.

1075 *See* SIFMA Comment Letter 2.

1076 *See id.*

1077 *See supra* section IV.D.1.c.

Because of the reasons described above,[1078] we are unable to estimate the likelihood of the different scenarios and, therefore, we are unable to quantify the efficiency and competition effects of the service provider provisions of the final amendments.

Some commenters requested that the Commission consider interactions between the effects of the proposed rule and other recent Commission rules, as well as practical realities such as implementation timelines.[1079] As discussed above, the Commission acknowledges that overlapping compliance periods may in some cases increase costs, particularly for smaller entities with more limited compliance resources.[1080] This effect can negatively impact competition because these entities may be less able to absorb or pass on these additional costs, making it difficult for them to remain in business or compete. We acknowledge that to the extent overlap occurs, there could be costs that could affect competition. However, we do not expect these costs to be significant, for two reasons. First, the final amendments mitigate overall costs relative to the proposal,[1081] including by adopting longer compliance periods for all covered institutions, and an even longer compliance period for smaller covered institutions because they may have more limited compliance resources. The final amendments also reduce costs for both larger and smaller entities, relative to the proposal, notably by removing the proposed requirement to have a written contract with service providers. Thus, any higher costs or potential negative effects on competition due to overlapping compliance periods raised in the context of the proposal may be mitigated under the final amendments. Second, as explained in section IV.D, many of the rules commenters named affect limited sets of covered institutions, and the

---

1078 *See id*.

1079 *See supra* section IV.C.

1080 *See supra* section IV.D.

1081 *See supra* section IV.B.

compliance dates are generally spread out over a more than three-year period, including several that precede the compliance dates of the final amendments. These factors will limit the incidence of covered institutions affected by overlapping compliance dates.

Additionally, we anticipate that neither the recordkeeping provisions nor the exception from annual privacy notice delivery requirements will have a notable impact on efficiency, competition, or capital formation due to their limited economic effects.[1082] As discussed elsewhere, we do not expect the recordkeeping requirements to impose material compliance costs, and we therefore expect the economic effects of the exception to be limited. And, as the economic effects of the recordkeeping provisions are limited, any overlapping compliance dates involving recordkeeping will likewise have limited effect on competition.

F. Reasonable Alternatives Considered

In formulating the final amendments, we have considered various reasonable alternatives. These alternatives are discussed below.

1. Reasonable Assurances from Service Providers

Rather than requiring the establishment, maintenance, and enforcement of written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of service providers to ensure service providers take appropriate measures to protect against unauthorized access to or use of customer information and provide notification to the covered institution if a breach of security occurs,[1083] the Commission considered requiring covered institutions to obtain "reasonable assurances" from service

---

[1082] *See* final rule 248.30(c) and final rule 248.5; *see also supra* sections IV.D.3 and IV.D.4.

[1083] *See* final rule 248.30(a)(5)(i).

providers instead. One commenter supported this alternative for some service providers.[1084] This alternative requirement would be a lower threshold than the final provisions requiring the establishment, maintenance, and enforcement of written policies and procedures designed to require oversight, and as such would be less costly to reach but also less protective for customers.

Under this alternative we would have used the final amendments' definition of "service provider," which is "any person or entity that receives, maintains, processes, or otherwise is permitted access to customer information through its provision of services directly to a covered institution."[1085] Thus, similar to the final amendments, this alternative could affect a broad range of service providers including, potentially: email providers, customer relationship management systems, cloud applications, and other technology vendors. Depending on the states where they operate, these service providers may already be subject to state laws applicable to businesses that "maintain" computerized data containing private information.[1086] Additionally, it is likely that any service provider that offers a service involving the maintenance of customer information to U.S. financial firms generally, or to any specific financial firm with a national presence, has processes in place to ensure compliance with these state laws.

For those service providers that provide specialized services aimed at covered institutions, this alternative would, like the final amendments, create market pressure to enhance service offerings so as to provide the requisite assurances and facilitate covered institutions'

1084 *See* SIFMA Comment letter 2. Other commenters also suggested alternative thresholds that would be lower than the final amendments' provisions. *See, e.g.*, IAA Comment Letter 1; AWS Comment Letter.

1085 Final rule 248.30(d)(10).

1086 *See, e.g.,* Cal. Civil Code § 1798.81.5(b) and 1798.82(b); N.Y. Gen. Bus. Law § 899-AA(3).

compliance with the requirements.[1087] These service providers might have little choice other than to adapt their services to provide the required assurances, which would result in additional costs for the service providers related to adapting business processes to accommodate the requirements. In general, we expect these costs would be limited in scale in the same ways the costs of the final amendments are limited in scale: specialized service providers are adapted to operating in a highly regulated industry and are likely to have policies and procedures in place to facilitate compliance with state data breach laws. And, as with the final amendments, we generally anticipate that such costs would largely be passed on to covered institutions and ultimately their customers. As compared to the final amendments' requirements, we expect that "reasonable assurances" would in many cases require fewer changes to business processes and, accordingly, lower costs.[1088] However, this alternative—without more—could also be less protective than the final amendments.

With respect to service providers providing services aimed at a broad range of institutions (e.g., email, or customer-relationship management), the situation could be different. For these providers, covered institutions are likely to represent a small fraction of their customer base. As under the final service provider provisions, these service providers may again be unwilling to adapt their business processes to the regulatory requirements of a small subset of their customers under this alternative.[1089] Some may be unwilling to make the assurances needed, although we anticipate that they would be generally more willing to make assurances than to participate in the

---

1087 A service provider involved in any business-critical function likely "receives, maintains, processes, or otherwise is permitted access to customer information." *See* final rule 248.30(d)(10).

1088 *See supra* section II.A.4 for a discussion of sufficient safeguards for ensuring compliance with covered institution's obligations under the final amendments.

1089 *See supra* section IV.D.1.c (discussing the final requirement for covered institutions to require policies and procedures reasonably designed to oversee, monitor, and conduct due diligence on service providers).

covered institutions' oversight activities.[1090] If the covered institution could not obtain the reasonable assurances required under this alternative, the covered institution would need to switch service providers and bear the associated switching costs, while the service providers would suffer loss of customers. Although the costs of obtaining reasonable assurances would likely be lower than under the final service provider provisions, and the need to switch providers less frequent, these costs could nonetheless be particularly acute for smaller covered institutions who lack bargaining power with some service providers. And, as outlined above, this alternative would be less protective than the final amendments' requirements.

2. Lower Threshold for Customer Notice

The Commission considered lowering the threshold for customer notice, such as one based on the "possible misuse" of sensitive customer information (rather than the adopted threshold requiring notice when sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization), or even requiring notification of any breach without exception. One commenter suggested that the final amendments require notification when the unauthorized access to or use of sensitive customer information was "reasonably possible" instead of "reasonably likely."[1091] A lower threshold would increase the number of notices customers receive. Although more frequent notices could potentially reveal incidents that warrant customers' attention and thereby potentially increase the benefits accruing to customers from the notice requirement discussed in section IV.D.1.b, they would also increase the number

---

1090 *See id.* Additionally, the service provider's standard terms and conditions might in some situations provide reasonable assurances adequate to meet the requirement.

1091 *See* NASAA Comment Letter. In addition, another commenter suggested requiring customer notification for any incident of unauthorized access to or use of sensitive customer information regardless of the risk of use in a manner that would result in substantial harm or inconvenience. *See* Better Markets Comment Letter.

of false alarms. Such false alarms could be problematic if they reduce customers' ability to discern which notices require action.

Although a lower threshold could impose some additional compliance costs on covered institutions (due to additional notices being sent), we would not anticipate the additional direct compliance costs to be significant.[1092] Of more economic significance to covered institutions would be the resulting reputational effects.[1093] However, the direction of these effects is difficult to predict. On the one hand, increased notices resulting from a lower threshold can be expected to lead to additional reputational costs for firms required to issue more of such notices. On the other hand, lower thresholds could result in customers receiving a large number of notices. In this case, notices could become no longer notable, likely leading to the negative reputation effects associated with such notices being reduced.

3. Encryption Safe Harbor

The Commission considered including a safe harbor to the notification requirement for breaches in which only encrypted information was compromised. Several commenters supported an encryption safe harbor.[1094] An encryption safe harbor would also align with many existing state laws.[1095] Assuming that such an alternative safe harbor would be sufficiently circumscribed to prevent its application to insecure encryption algorithms, or to secure algorithms used in a manner as to render them insecure, the economic effects of its inclusion would be largely indistinguishable from the final amendments. This is because under the final amendments, notification is triggered by the "reasonable likelihood" that sensitive customer information was

---

1092 The direct compliance costs of notices are discussed in section V.

1093 *See supra* section IV.B.

1094 *See, e.g.*, SIFMA Comment Letter 2; AWS Comment Letter 1. *See also supra* section II.A.3.b for a discussion of the comments received on this matter.

1095 *See supra* section IV.C.2.a(1).